

Paste this into a strong coding AI to rebuild a production-grade CFS-style EMS in one program. Derived from CFS Designers latest docs + shipped behavior.

Copy the PROMPT block below into Cursor / Claude / GPT. Attach empty repo or greenfield. Say: follow the prompt exactly; do not invent other industries; no DB wipe scripts in prod.

■■■■■■■■■■ PROMPT START ■■■■■■■■■■

Role: You are a principal engineer + senior product designer (30+ years) shipping a **Cold Formed Steel / LGS studio EMS** for a company like CFS Designers. Not civil roads/bridges. Markets: US/AU/global; office Islamabad. Brand: Black + Gold + White, Playfair + Nunito. Ship production-ready: secure, fast, reusable, visually finished.

Product one-liner: Workforce attendance + screenshots (PC Agent) + office Manager (Desktop Tauri + Web) + CFS project pipeline + soft payment gate + invoices + partner shares + daily/monthly PDFs + office notify bell. Phone = Admin/HR glance PWA only — never employee punch.

Stack (lock):

- API: Python 3.11+, FastAPI, SQLAlchemy async, SQLite (prod path durable), JWT (user + device typ), bcrypt, reportlab PDFs.
- Web/Desktop: React + TypeScript + Vite; same UI in Tauri 2 Desktop Manager.
- Agent: Python PySide6 + PyInstaller zip; enroll code; Sign In/Out/Break; idle; multi-monitor JPEG screenshots; offline outbox.
- Deploy: nginx + systemd on VPS (Hostinger-class); HTTPS only; OpenAPI disabled in prod.

Roles & authorization (non-negotiable):

- admin / manager = finance (\$ Invoices, Advance/Deposit badges, payment soft-gate UI).
- hr = office ops, Live/Day/Employees/Projects/Expenses/Reports; NO payment \$; NO Advance badges.
- employee = own Day, assigned projects, My % progress; NO Downloads nav; NO payment wording; gate field blanked in API.
- demo = isolated tour; never mix real client money.
- Partner shares = named admin partners only.
- Screenshots/Day of others = office roles or self only; path traversal blocked under data_dir.

Core feature modules (build all):

- Auth login/logout; employee CRUD; enroll codes for Agent devices.
- Live presence + Day timeline + activity buckets + screenshot lightbox + audit on view.
- Dashboard: presence, week hours charts, roster, end-of-day % today + Past 7 days grouped by employee accordion (aligned meta column).
- Staff home: attendance trends (work-day avg), assigned work scroll + hide finished, personal monthly PDF.
- Projects Kanban phases: Intake → Prelim Design → Prelim Eng → Final Eng → Stamped → Field → Run. Soft gate leaving Intake without Paid deposit (notify admin); HARD lock Stamped/Field/Run until finance clears.
- Payments / invoices PDF parity; expenses; partner share ledger with FX.
- Office notification center: bell, unread badge, mark read, soft chime after user-gesture audio unlock; Test sound button.
- Reports: professional daily + monthly PDFs (no blank orphan pages; charts ≤ content width).
- Downloads page: Admin/HR only — Manager Setup + Agent zip.
- Admin/HR PWA install banner on HTTPS; SW must never cache /api.
- Click→background update MVP: version endpoint; Agent zip apply preserving config.json + agent_data; Manager silent Setup /S; never touch server DB.

UI / UX bar:

- Finished spacing/type/contrast; dark + light themes; gold accents; no purple-AI cliché.
- Desktop-first Manager; responsive but not a toy. Kanban usable on wide monitors.
- Empty states, loading, toasts, confirm deletes. Keyboard focus visible.
- Sensitive badges never shown to non-finance. Client names masked to initials for staff where required.

Security / production (big-tech bar):

- Refuse weak SECRET_KEY; EMS_ENV=production disables sample seed; security headers (nosniff, DENY frame, Permissions-Policy).
- CORS allowlist exact origins (web + Tauri). Prepared statements / ORM only.

- Upload MIME allowlist + size caps + random names; no PHP/exec in upload trees.
- Rate-limit login at reverse proxy; short-lived tokens preferred; no secrets in git.
- Updater: HTTPS host allowlist now; plan Authenticode / signed Tauri updater next.
- Retention job for old screenshots; audit log for sensitive views.
- Never ship destructive “reset DB” in production paths.

NFR:

- Timezone Asia/Karachi for work dates; utf8mb4/sqlite unicode safe.
- Admin save/upload feels responsive; lazy images; paginate large lists.
- SEO N/A for private EMS; still semantic HTML + a11y labels.

Delivery order:

- 1) API auth + employees + Agent enroll/heartbeat/screenshots.
- 2) Manager Live/Day/Reports PDFs.
- 3) Projects + soft/hard payment gate + Payments.
- 4) Desktop Tauri shell + Agent packaging.
- 5) Notify + PWA Admin/HR + click-update.
- 6) Ops docs: QA matrix, security audit, deploy, break/fix, auto-update honesty.

Definition of done:

- Role matrix tested; employee cannot see Advance pending or Downloads.
- One Agent full day cycle; one Admin phone PWA; PDFs clean; notify Test sound works.
- Update click preserves enroll; server DB untouched.
- STATUS.md + version bump (Manager + Agent + API latest) in sync.

Out of scope unless asked: marketplace SaaS, public client portal v1, employee mobile punch, roads/geotech modules.

■■■■■■■■■■■■■■■■■■■■ **PROMPT END** ■■■■■■■■■■■■■■■■■■■■

Companion checklist (what “big tech ready” adds later)

- SSO/OIDC, hardware-backed session store, CSP + Trusted Types.
- Signed binaries + SBOM + vulnerability scanning in CI.
- Immutable audit warehouse; SOC2-style access reviews.
- Multi-region backups; PITR; chaos drills for Agent update.
- Feature flags; canary Desktop builds.

This prompt mirrors CFS EMS pack v0.1.6 / Agent 1.1.6 on branch desktop+agent.